

## TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

---

GUIDE-ISO-01

# ISO 27001 Explained

A Clear Introduction to the World's Leading Information Security Management Standard  
**TSEC Compliance Insights | ISO 27001 Series**

|                 |                                |
|-----------------|--------------------------------|
| Document ID:    | GUIDE-ISO-01                   |
| Version:        | 2026 Edition                   |
| Effective Date: | June 2026                      |
| Classification: | <b>CONFIDENTIAL</b>            |
| Prepared by:    | TSEC Risk & Cyber Advisory LLC |

---

TSEC Compliance Insights | TSEC Risk & Cyber Advisory LLC | [www.tsecgrc.com](http://www.tsecgrc.com) | [info@tsecgrc.com](mailto:info@tsecgrc.com)

# 1. What Is ISO 27001?

ISO/IEC 27001 is the leading international standard for information security management. Published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), the standard specifies the requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). The most recent version — ISO/IEC 27001:2022 — was published in October 2022 and introduced an updated Annex A control set, restructuring controls from 14 domains (in the 2013 version) into four thematic areas covering 93 controls.

## 2. Why Organizations Pursue ISO 27001

ISO 27001 certification signals to customers, partners, regulators, and investors that an organization has implemented a structured, internationally recognized approach to information security — one that has been independently verified by a third-party certification body. Common drivers include:

- Customer and contractual requirements: procurement teams at larger organizations, government agencies, and regulated industries increasingly mandate ISO 27001 certification as a vendor qualification
- Regulatory alignment: many national data protection regulations and sector-specific regulations recognize or reference ISO 27001 as a baseline for technical and organizational security measures
- Market differentiation: certification provides a credible, independently verified signal of security maturity in competitive procurement processes
- Internal program structure: the ISO 27001 framework provides a systematic approach to building and maturing an information security program across people, process, and technology
- International market access: ISO 27001 is recognized globally, making it particularly valuable for organizations operating across multiple jurisdictions

## 3. The Structure of ISO 27001:2022

ISO 27001:2022 follows the High Level Structure (HLS) common to all ISO management system standards, making it compatible with ISO 9001 (quality management) and ISO 14001 (environmental management). The standard's normative requirements are organized into Clauses 4 through 10, while Annex A provides the control reference.

| Clause | Topic                       | Summary                                                                                               |
|--------|-----------------------------|-------------------------------------------------------------------------------------------------------|
| 4      | Context of the Organization | Understanding internal and external issues, interested parties, and determining the scope of the ISMS |
| 5      | Leadership                  | Top management commitment, Information Security Policy, and assignment of roles and responsibilities  |
| 6      | Planning                    | Risk assessment and treatment, information security objectives, and planning for changes              |
| 7      | Support                     | Resources, competence, awareness, communication, and documented information                           |
| 8      | Operation                   | Operational planning, risk assessment execution, and risk treatment implementation                    |

|         |                        |                                                                                                          |
|---------|------------------------|----------------------------------------------------------------------------------------------------------|
| 9       | Performance Evaluation | Monitoring and measurement, internal audit, and management review                                        |
| 10      | Improvement            | Nonconformity and corrective action; continual improvement                                               |
| Annex A | Reference Control Set  | 93 controls organized in four themes: Organizational (37), People (8), Physical (14), Technological (34) |

## 4. Risk-Based Approach: The Heart of ISO 27001

Unlike prescriptive compliance frameworks that specify a fixed list of controls that every organization must implement, ISO 27001 is built on a risk-based approach. Organizations identify and assess risks to the confidentiality, integrity, and availability of their information, determine appropriate treatment options, and select controls from Annex A (and potentially from other sources) that are necessary to address those risks.

This means that two organizations in the same industry may implement quite different sets of controls — because they have different risk profiles, different technology environments, and different business contexts. The Statement of Applicability is the document that records this determination for each Annex A control.

## 5. ISO 27001 vs. SOC 2: Key Differences

| Dimension                | ISO 27001                                                                                                                          | SOC 2                                                                                                          |
|--------------------------|------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| Standard setter          | International Organization for Standardization (ISO)                                                                               | American Institute of Certified Public Accountants (AICPA)                                                     |
| Output                   | Certification — issued by an accredited certification body, valid for 3 years with annual surveillance audits                      | Report — issued by a licensed CPA firm for a specific examination period; typically renewed annually           |
| Geographic recognition   | Global — recognized across most jurisdictions and industries worldwide                                                             | Primarily North America — most recognized in the United States                                                 |
| Approach                 | Management system — evaluates whether an organization has implemented and is operating an ISMS meeting the standard's requirements | Trust Services Criteria — evaluates whether specific controls meet defined criteria over an examination period |
| Control prescriptiveness | Risk-based — Annex A controls are selected based on the organization's risk assessment                                             | Criteria-based — controls must address each applicable TSC criterion                                           |
| Best suited for          | Organizations with global operations or customers; organizations seeking a comprehensive management system framework               | Technology companies serving US enterprise customers; SaaS providers in vendor due diligence processes         |

## 6. The Certification Process

ISO 27001 certification involves a two-stage audit by an accredited certification body:

- **Stage 1 (Documentation Review):** The auditor reviews the organization's ISMS documentation — scope, policies, risk assessment, Statement of Applicability — to confirm the ISMS is designed to meet the standard's requirements and is ready for Stage 2
- **Stage 2 (Certification Audit):** The auditor assesses the effectiveness of the ISMS implementation, including interviews with personnel, observation of processes, and review of records

- Surveillance Audits: Following certification, surveillance audits are conducted annually to confirm the ISMS continues to meet requirements
- Recertification: Every three years, a full recertification audit is conducted

## 7. Key Takeaways

- ISO 27001:2022 is the global standard for information security management — recognized by customers, regulators, and procurement teams worldwide
- Its risk-based approach means controls are selected to address your specific risks — not prescribed uniformly for every organization
- The Statement of Applicability is the critical document recording how each Annex A control applies (or doesn't) to your organization
- Certification involves a two-stage audit and is maintained through annual surveillance audits and a three-year recertification cycle
- ISO 27001 and SOC 2 are complementary rather than competing — many organizations pursue both, using overlapping controls to satisfy different market requirements

## 8. New Controls in ISO 27001:2022

The 2022 revision introduced 11 new controls that were not present in the 2013 version, reflecting the evolution of the security landscape since the prior edition. Organizations migrating from a 2013 certification to 2022 should pay particular attention to these controls when updating their Statement of Applicability.

| New Control                                         | Theme          | What It Addresses                                                           |
|-----------------------------------------------------|----------------|-----------------------------------------------------------------------------|
| 5.7 Threat intelligence                             | Organizational | Collecting and using information about threats relevant to the organization |
| 5.23 Information security for use of cloud services | Organizational | Security requirements and management for use of cloud services              |
| 5.30 ICT readiness for business continuity          | Organizational | Ensuring ICT systems can support business continuity                        |
| 7.4 Physical security monitoring                    | Physical       | Monitoring premises for unauthorized physical access                        |
| 8.9 Configuration management                        | Technological  | Establishing and managing secure configurations                             |
| 8.10 Information deletion                           | Technological  | Ensuring information is deleted when no longer required                     |
| 8.11 Data masking                                   | Technological  | Masking data to protect PII and sensitive information                       |
| 8.12 Data leakage prevention                        | Technological  | Detecting and preventing unauthorized disclosure of information             |
| 8.16 Monitoring activities                          | Technological  | Monitoring networks, systems, and applications for anomalous behavior       |
| 8.23 Web filtering                                  | Technological  | Managing access to external websites                                        |
| 8.28 Secure coding                                  | Technological  | Ensuring security principles are applied in software development            |

## 9. ISO 27001 Across Industries

While ISO 27001 was originally developed with information technology organizations in mind, it has become relevant across virtually every industry sector, driven by the universal need to manage digital information securely. Sector-specific observations:

- Financial services: ISO 27001 is recognized by regulators in many jurisdictions as evidence of a mature information security management system, though it typically does not replace sector-specific requirements (e.g., NYDFS Part 500, PCI DSS)
- Healthcare: Organizations that handle protected health information in countries covered by GDPR or similar laws find ISO 27001 a useful framework for demonstrating the 'appropriate technical and organizational measures' required by data protection law
- Government contracting: Many government procurement processes — particularly in Europe and Asia — treat ISO 27001 certification as a qualification criterion
- SaaS and technology vendors: Increasingly standard in enterprise B2B sales, where procurement teams use ISO 27001 as a fast-track signal of security maturity alongside or instead of a SOC 2 report

## 10. Costs and Timeline for ISO 27001 Certification

| Cost / Timeline Element                                       | Typical Range                                                                  |
|---------------------------------------------------------------|--------------------------------------------------------------------------------|
| Certification body audit fees (Stage 1 + Stage 2, first year) | \$8,000 — \$25,000+ depending on organization size and scope                   |
| Annual surveillance audit fees (Years 2 and 3)                | \$4,000 — \$12,000 per year                                                    |
| Triennial recertification audit                               | Similar to initial Stage 1+2 cost                                              |
| Advisory / readiness support (optional)                       | \$15,000 — \$75,000+ depending on scope of support and current maturity        |
| Compliance tooling (optional)                                 | \$5,000 — \$30,000 per year depending on platform                              |
| Internal staff time (readiness and ongoing)                   | Significant — typically 0.5 to 2 FTE equivalent depending on organization size |
| Time from starting implementation to certification            | Typically 9 — 18 months for a first-time certification                         |